ACTIVIDAD 7

Enumeración de Directorios Web

Python y Ciberseguridad

Antes de empezar...	
Nombre	Iker
Apellidos	Martinez Bermudez
Fecha	14/05/2026

Resultados de Aprendizaje

RA2 - Identifica las principales amenazas digitales y los vectores de ataque más habituales, y aplica mecanismos de protección de la información adecuados a cada tipo de riesgo.

2.2 Identifica y clasifica las principales amenazas y vulnerabilidades que pueden afectar a sistemas informáticos, relacionando cada tipo de ataque con contramedidas concretas.

2.6 Configura y gestiona mecanismos de autenticación (2FA/MFA), roles, perfiles y permisos en sistemas operativos y aplicaciones.

Contexto

Al acceder a la interfaz web de Metasploitable (http://<IP_de_Metasploitable>), probablemente notaste que puedes navegar libremente por diferentes carpetas: DVWA, Mutillidae, phpMyAdmin...

Esto no es normal en un servidor web bien configurado. El servidor Apache tiene habilitada la opción *Options +Indexes*, que permite **listar el contenido de directorios que no tienen archivo index.html**. Es como dejar las puertas de tu casa abiertas con un cartel que dice "entra y mira lo que hay".

PROBLEMA: Apache está configurado con **Directory Listing habilitado**, lo que expone la estructura de carpetas y archivos del servidor web. Un atacante puede:

- Descubrir aplicaciones web vulnerables (versiones antiguas de phpMyAdmin, DVWA, etc.)
- Encontrar archivos sensibles (.sql, .bak, .git, config.php)
- Identificar tecnologías usadas (versiones de frameworks, librerías)

- Mapear la estructura completa del sitio sin necesidad de fuerza bruta

Esto viola el principio de "mínima exposición de información" (Information Disclosure).

Preparación del entorno

Antes de empezar, verifica que tienes:

- **Máquina víctima:** Metasploitable 2 ejecutándose
    - **Red:** Adaptador **host-only**
- **Máquina Atacante:** Kali Linux / Ubuntu con las siguientes herramientas instaladas:
    - Navegador web (Firefox/Chrome)
    - Dirb (si no está: sudo apt-get install dirb)
    - Curl (si no está: sudo apt-get install curl)
    - **Red:**
        - **Adaptador 1 host-only** (misma red que Metasploitable)
        - **Adaptador 2 NAT** (para Internet)

Actividades

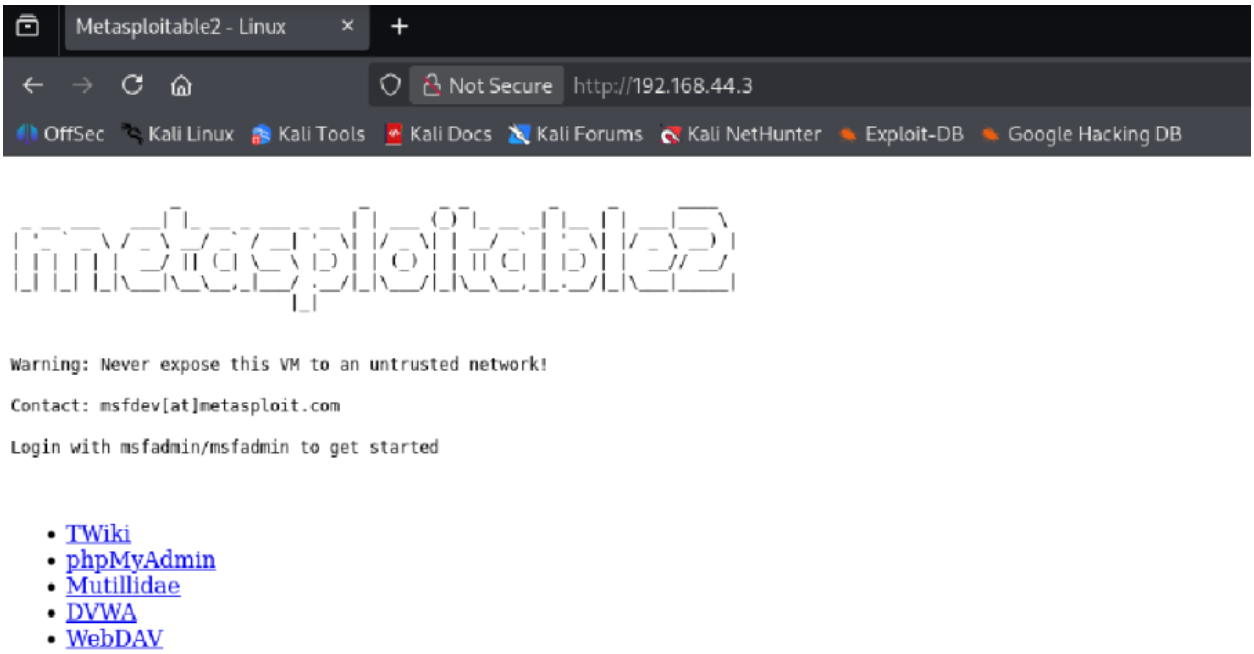
PARTE 1: Enumeración manual de directorios

Primero vamos a explorar manualmente el servidor web para ver qué información expone.

Abre tu navegador y accede a: http://<IP_de_Metasploitable>

Captura de pantalla 1: Navegador mostrando el listado de directorios en la raíz del servidor web.

Intenta navegar por las carpetas visibles.



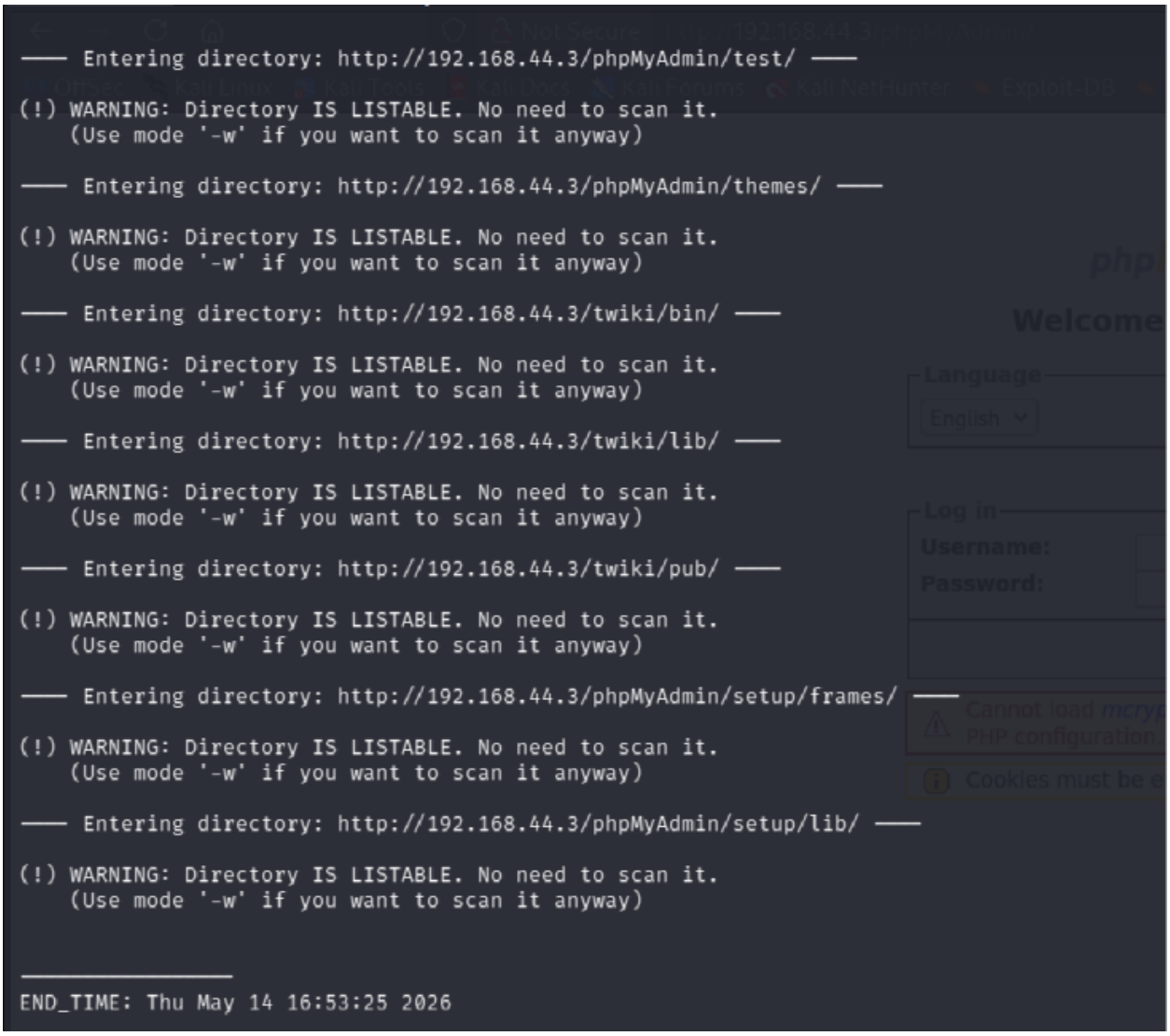
PARTE 2: Enumeración automática con Dirb

Ahora vamos a usar **Dirb**, una herramienta que automáticamente busca directorios y archivos comunes en un servidor web usando un diccionario.

En tu terminal de Kali/Ubuntu, ejecuta: dirb http://<IP_de_Metasploitable>

Dirb empezará a probar miles de rutas comunes (admin, backup, config, test...) y te mostrará cuáles existen.

El escaneo tardará varios minutos. Espera a que termine.



Captura de pantalla 3: Salida de Dirb mostrando directorios encontrados.

Responde:

- ¿Cuántos directorios encontró Dirb?
  El escaneo identificó al menos 5 directorios principales (dav/, phpMyAdmin/, test/, twiki/, cgi-bin/) y decenas de archivos y subdirectorios dentro de ellos.

- Nombra 5 directorios interesantes que haya descubierto

  `/phpinfo.php` (Muestra toda la configuración interna de PHP).

  `/phpMyAdmin/changelog` (Permite saber la versión exacta de la aplicación).

  `/dav/` (Marcado por Dirb como "LISTABLE", peligroso por exposición de archivos).

`/phpMyAdmin/libraries/` (Directorio interno que debería estar protegido).

`/phpMyAdmin/setup/` (Ruta para configurar la aplicación, crítico si es accesible).

PARTE 3: Análisis de riesgo - Búsqueda de archivos sensibles

Paso 1: Busca archivos de configuración expuestos

Con base en los resultados del escaneo con Dirb, navega por las carpetas disponibles y intenta encontrar informaciones sensibles.

Pregunta a tu IA favorita: "qué tipos de archivos pueden contener información sensible? " y busca por ellos :)

Encuentra 3 archivos sensibles y registra:

1. Nombre del archivo.
2. Ruta del archivo.
3. Por qué este archivo puede ser sensible?

Nombre del archivo	Ruta del archivo	¿Por qué este archivo puede ser sensible?
phpinfo.php	/phpinfo.php	Expone variables de entorno, rutas del sistema, extensiones cargadas y versiones de software, facilitando la creación de un exploit.
changelog	/phpMyAdmin/changelog	Revela el historial de cambios y la versión precisa del software, permitiendo buscar vulnerabilidades conocidas .
config.inc.php	/phpMyAdmin/config.inc.php	Es el archivo principal de configuración; si es accesible, expone las credenciales de la base de datos.

Captura de pantalla 4: Acceso a algún directorio sensible.



PHP Version 5.2.4-2ubuntu5.10

System	Linux metasploitable 2.6.24-16-server #1 SMP Thu Apr 10 13:58:00 UTC 2008 i686
Build Date	Jan 6 2010 21:50:12
Server API	CGI/FastCGI
Virtual Directory Support	disabled
Configuration File (php.ini) Path	/etc/php5/cgi
Loaded Configuration File	/etc/php5/cgi/php.ini
Scan this dir for additional .ini files	/etc/php5/cgi/conf.d
additional .ini files parsed	/etc/php5/cgi/conf.d/gd.ini, /etc/php5/cgi/conf.d/mysql.ini, /etc/php5/cgi/conf.d/mysqli.ini, /etc/php5/cgi/conf.d/pdo.ini, /etc/php5/cgi/conf.d/pdo_mysql.ini
PHP API	20041225
PHP Extension	20060613
Zend Extension	220060519
Debug Build	no
Thread Safety	disabled
Zend Memory Manager	enabled
IPv6 Support	enabled
Registered PHP Streams	zip, php, file, data, http, ftp, compress.bzip2, compress.zlib, https, ftps
Registered Stream	tcp, udp, unix, udg, ssl, sslv3, sslv2, tls

Responde:

- Si encuentras phpMyAdmin, intenta acceder. ¿Te deja entrar sin autenticación? ¿Qué versión es? ¿Por qué esta información es relevante?

  Al acceder, se observa la pantalla de login. En Metasploitable 2 suele ser root sin contraseña. La versión es antigua. Es relevante porque un atacante puede buscar fallos de seguridad específicos para esa versión y tomar el control total de las bases de datos.

- Si un atacante encuentra un archivo .sql o .bak expuesto, ¿qué podría hacer con él?

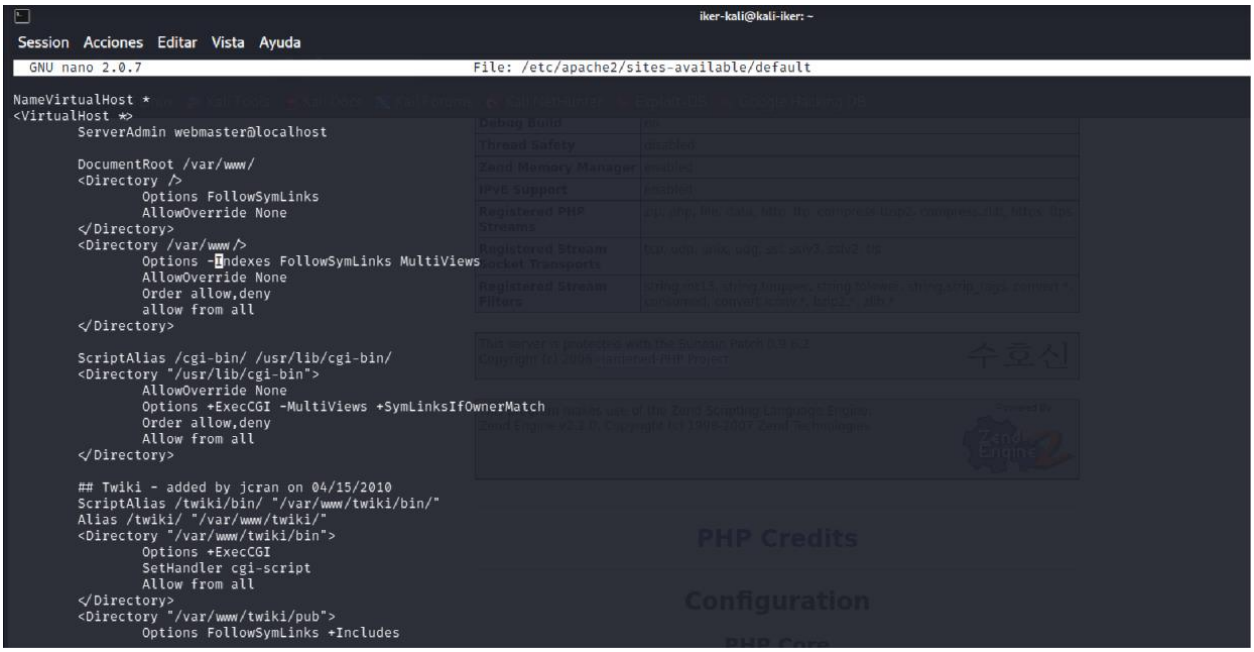
Podría descargar toda la base de datos de usuarios o ver copias de seguridad de archivos de configuración antiguos que contengan contraseñas olvidadas pero válidas.

PARTE 4: Solución - Deshabilitar Directory Listing

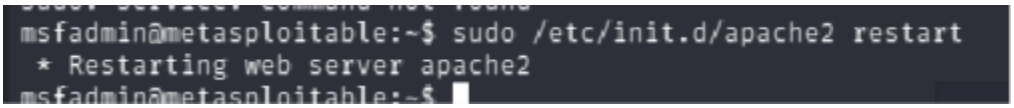
Ahora vamos a aplicar la contramedida: desactivar el listado de directorios en Apache.

Paso 1: Conéctate a Metasploitable por SSH, abre el archivo de configuración de Apache y deshabilita el listado de directorios.

Captura de pantalla 5: Archivo de configuración modificado.



Paso 2: Reinicia el servicio de Apache

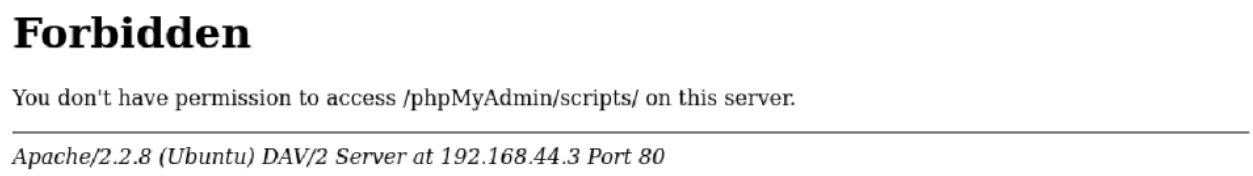


Paso 3: Verifica que ya no funciona

Vuelve a tu navegador e intenta acceder de nuevo a algunos de los directorios que accediste en el paso anterior.

Captura de pantalla 6: Error al intentar acceder a un directorio sin index.html. (Cómo se sabe que da error?)
?

Se sabe que el servidor está devolviendo un error porque el navegador muestra el mensaje "403 Forbidden". Técnicamente, esto significa que el servidor ha recibido la solicitud, pero se niega a autorizarla debido a la nueva configuración de seguridad. , ahora el servidor responde con una página de error que indica explícitamente: "You don't have permission to access /directory/ on this server".

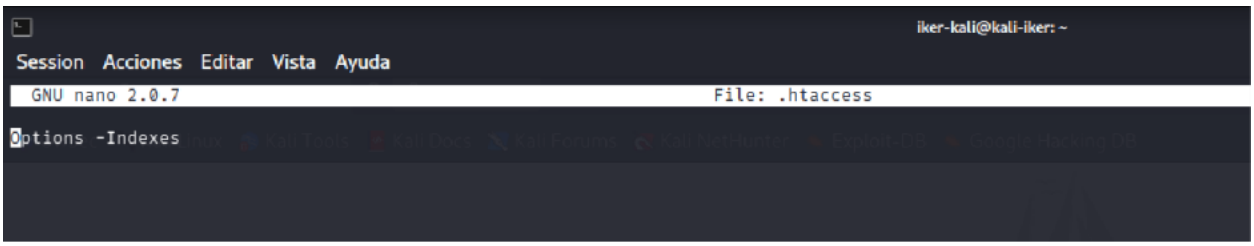


PARTE 5: Protección adicional con .htaccess

Además de deshabilitar el listing, podemos bloquear el acceso a archivos sensibles como .git, .sql, .bak, config.php.

Busca como crear un archivo .htaccess y cómo añadir reglas que bloqueen es acceso a archivos sensible.

Captura de pantalla 7: Contenido del archivo .htaccess.



Entregables

Este documento completado con:

- Todas las respuestas a las preguntas planteadas
- Las capturas de pantalla solicitadas